Vulnerability Assessment Report

Publicly Accessible Database Server | E-commerce Business | NIST SP 800-30 Rev. 1 | 1 January 20XX

Purpose

This assessment evaluates risks associated with the company's publicly accessible database server. The database stores information employees use to identify potential customers, making it important to daily operations. Unauthorized access could expose customer or business information and cause reputational, financial, or legal harm. If the database becomes unavailable or data is altered or deleted, employees may be unable to perform essential tasks, disrupting business operations and reducing customer trust.

Risk Assessment

Qualitative scores: likelihood 1–3 × severity 1–3 = risk score 1–9. Scores are estimates based on the supplied scenario.

Threat source	Threat event	Likelihood	Severity	Risk
Outsider / hacker	Obtain sensitive information via exfiltration	**3 High**	**3 High**	**9**
Standard user / employee	Alter or delete critical information	**2 Moderate**	**3 High**	**6**
Competitor / malicious actor	Conduct a Denial of Service (DoS) attack	**2 Moderate**	**3 High**	**6**

Approach

The assessment prioritizes threats to database confidentiality, integrity, and availability. Public internet access makes unauthorized connection attempts more likely. Data exfiltration could expose sensitive information, while unauthorized changes or deletion could compromise data integrity. A DoS attack could prevent employees from accessing information required for daily work. Scores reflect the estimated likelihood of each event and its potential impact on business operations.

Remediation Strategy

Immediately remove direct public access and permit connections only through a private network or approved VPN protected by multi-factor authentication (MFA). Apply least privilege and role-based permissions so accounts can access only required data. Implement authentication, authorization, and accounting (AAA), plus audit logging to identify suspicious access and changes. Use supported TLS configurations, patch the operating system and database, and maintain tested, isolated backups. Review existing logs for evidence of prior unauthorized access.

Limitations

This is a qualitative, scenario-based assessment, not a penetration test or confirmation of a breach. Ratings should be validated against access-control settings, network exposure, logs, and business requirements. The reported public exposure makes log review a priority.

Reference: NIST SP 800-30 Rev. 1, Guide for Conducting Risk Assessments. Educational portfolio exercise based on the supplied scenario.